

中华人民共和国通信行业标准

YD/T XXXXX—202X
[代替 YD/T]

网络安全仿真 恶意软件危害性测评方法

Network security emulation environment — Testing and evaluation method of
malware risk

(报批稿)

XXXX – XX – XX 发布

XXXX – XX – XX 实施

中华人民共和国工业和信息化部 发布

目 次

前言..... II

1 范围..... 1

2 规范性引用文件..... 1

3 术语和定义..... 1

4 缩略语..... 2

5 测试对象..... 2

 5.1 恶意软件..... 2

 5.2 恶意软件防护系统..... 3

6 测评环境..... 3

 6.1 整体架构..... 3

 6.2 功能要求..... 3

7 测试准备..... 3

 7.1 测试对象准备..... 3

 7.2 网络安全仿真测评环境初始化..... 3

8 恶意软件测试过程..... 3

 8.1 恶意软件攻击..... 4

 8.2 获取数据..... 4

9 恶意软件危害性评估..... 4

 9.1 评估准则..... 4

 9.2 恶意软件危害性评估框架和流程..... 4

 9.3 恶意软件危害性评估实施..... 6

 9.4 恶意软件危害性分级..... 10

附 录 A （资料性） 恶意软件危害性计算方法..... 11

 A.1 破坏性级别的计算..... 11

 A.2 危害性级别的计算..... 11

前 言

本文件按照GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由中国通信标准化协会提出并归口。

本文件的牵头起草单位：南开大学、广州大学网络空间先进技术研究院、国家计算机网络应急技术处理协调中心、鹏程实验室、哈尔滨工业大学（深圳）。

本文件的参与起草单位：南京理工大学、电子科技大学广东电子信息工程研究院、湖南合天智汇信息技术有限公司、武汉安天信息技术有限责任公司、新华三技术有限公司、中国电信集团有限公司、中国移动通信集团有限公司、中国信息通信科技集团有限公司。

本文件主要起草人：张健、王志、张玉、刘哲理、李树栋、舒敏、贾焰、田志宏、韩伟红、吴晓波、郑禄鑫、王湘懿、杨铭、弋晓洋、廖清、李千目、陈雷霆、曹厚华。

网络安全仿真 恶意软件危害性测评方法

1 范围

本文件面向网络安全仿真环境，分析恶意软件攻防场景，提出了恶意软件测试运行的要求，规定了恶意软件攻防过程中，检测环境搭建、数据采集、危害性评估的方法和依据。

本文件适用于网络安全仿真环境中的恶意软件危害性测试和评估。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

GB/T 25068.1-2020 信息技术 安全技术 网络安全 第1部分：综述和概念

3 术语和定义

下列术语和定义适用于本文件。

3.1

恶意软件 malware

被专门设计用于损坏或中断系统、破坏保密性、完整性和/或可用性的软件。

注：病毒和特洛伊木马都是恶意软件。

[GB/T 25068.1-2020，定义 3.22]

3.2

虚拟机带外检测 out-of VM detection

运用虚拟化技术，在特权虚拟机中获取目标虚拟机中的进程，内存，磁盘等内部状态信息，用以检测虚拟机的异常状态，具有透明性，隔离性，可靠性等特点。

3.3

误报 false positive

恶意软件防护机制将正常系统或文件报为含有恶意软件，或将正常操作报为恶意行为。

3.4

误报率 rate of false positive

恶意软件防护机制将正常系统或文件报为含有恶意软件，或将正常操作报为恶意行为的比例。

4 缩略语

下列缩略语适用于本文件。

VMI: 虚拟机自省 (Virtual Machine Introspection)

VM: 虚拟机 (Virtual Machine)

5 测试对象

5.1 恶意软件

5.1.1 恶意软件种类

恶意软件应至少包含以下种类:

- a) 文件感染型病毒;
- b) 宏病毒;
- c) 蠕虫;
- d) 木马程序;
- e) 间谍软件;
- f) 脚本恶意程序;
- g) 后门程序;
- h) 僵尸程序;
- i) 勒索软件;
- j) Rootkit恶意程序;
- k) Bootkit恶意程序。

5.1.2 恶意软件属性

恶意软件包含以下属性:

- a) 恶意软件使用的战术;
- b) 恶意软件使用的技术;
- c) 恶意软件的危害性;
- d) 恶意软件依赖的软硬件环境。

5.2 恶意软件防护系统

5.2.1 恶意软件防护系统类型

恶意软件防护系统按照其运行环境分为以下类型:

- a) 主机型;
- b) 网络型;
- c) 嵌入式。

5.2.2 恶意软件防护系统属性

- a) 恶意软件防护系统的功能;
- b) 恶意软件防护系统依赖的软硬件环境;
- c) 恶意软件防护系统的配置参数。

6 测评环境

6.1 整体架构

网络安全仿真测评环境应由硬件资源、虚拟网络、应用模拟、运维管理、安全管理、用户、数据采集、分析评估等模块构成。

6.2 功能要求

网络安全仿真测评环境应具有以下功能：

- a) 测试环境可以快速生成测试用例正常运行需要的软硬件环境和服务；
- b) 在测试过程中采用VMI等技术通过带内、带外等方式采集获取各类数据的能力；
- c) 能够对测试数据进行存储、处理、检索和展示，为分析评估提供支撑；
- d) 测试环境具有内部安全隔离功能，可以同时独立运行多个测试对象，互不影响；
- e) 测试环境具有与外部网络安全隔离的功能。

7 测试准备

7.1 测试对象准备

对测试对象的准备工作如下：

- a) 分析确认测试对象的类别；
- b) 分析确认测试对象的属性。

7.2 网络安全仿真测评环境初始化

根据测试用例的类别和属性，初始化网络安全仿真测评环境：

- a) 按照恶意软件测试对象的特性，配置其运行的软硬件环境和服务；
- b) 按照恶意软件防护系统的安装要求，配置软硬件环境。

8 恶意软件测试过程

8.1 恶意软件攻击

恶意软件攻击过程如下：

- a) 侦察：收集信息，侦察目标；
- b) 恶意软件准备：对恶意软件进行配置，做好攻击准备；
- c) 投放：根据恶意软件的属性，通过电子邮件、网络、USB等方式进行投放；
- d) 利用：利用目标系统上的漏洞执行恶意软件；
- e) 安装：安装恶意软件；
- f) 命令与控制：对目标系统通过网络进行远程控制；
- g) 目标达成：实现设定的目标，例如窃取数据、远程控制、进行勒索、实施破坏等。

8.2 获取数据

获取测试数据的方式如下：

- a) 获取系统内各类日志数据；

- b) 旁路获取网络数据;
- c) 带外方式获取数据。

9 恶意软件危害性测评

9.1 测评方法

通过对恶意软件结构和特征、传播机制、自我保护机制和危害性的分析，提出影响恶意软件危害性的关键要素。参照GB/T 31722-2015 《信息技术 安全技术 信息安全风险管理》，提出恶意软件危害性的测评方法。

9.2 恶意软件危害性评估框架和流程

9.2.1 危害性要素关系

恶意软件危害性评估中各要素的关系如图1所示。

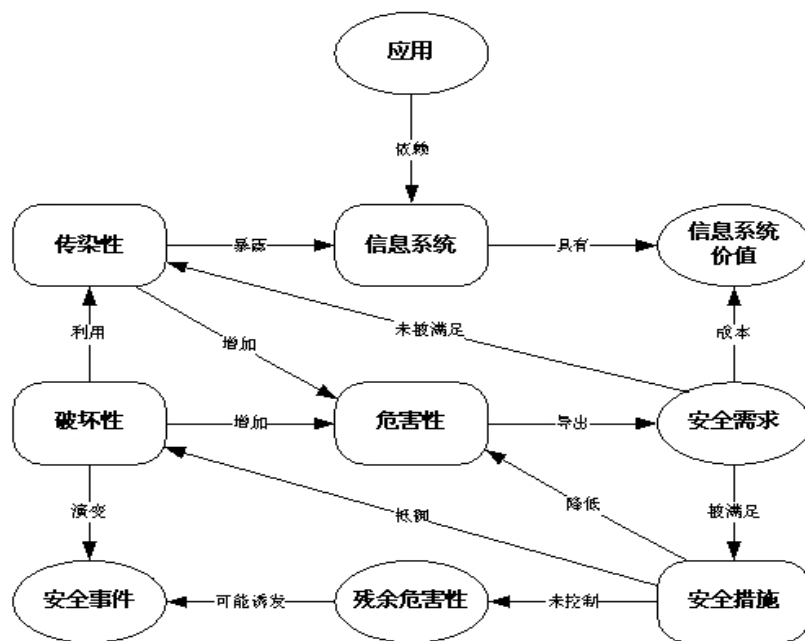


图1 危害性评估要素关系图

图1中方框部分的内容为危害性评估的基本要素，椭圆部分的内容是与这些要素相关的属性。危害性评估围绕着信息系统、传染性、破坏性和安全措施这些基本要素展开，在对基本要素的评估过程中，需要充分考虑应用、信息系统价值、安全需求、安全事件、残余危害性等与这些基本要素相关的各类属性。

9.2.2 危害性分析原理

危害性分析原理如图2所示。

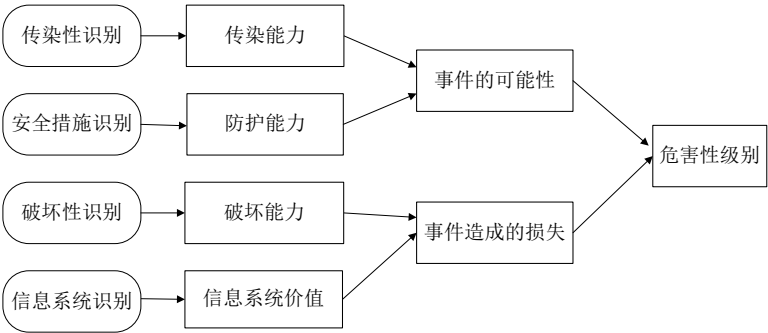


图2 危害性分析原理图

危害性分析中要涉及信息系统、安全措施、传染性、破坏性四个基本要素，因此要对这四个要素包含的属性进行分析，分别对其进行识别。危害性分析的主要内容：

- a) 对信息系统价值、防护能力、传染性和破坏性进行识别，描述其各自属性，并对四个要素进行赋值；
- b) 根据传染能力及防护能力判断恶意软件安全事件发生的可能性；
- c) 根据破坏能力及恶意软件安全事件所作用的信息系统的价值计算恶意软件安全事件造成的损失；
- d) 根据恶意软件安全事件发生的可能性以及安全事件出现后造成的损失，计算恶意软件安全事件一旦发生对信息系统的影响，即危害性级别。

9.2.3 实施流程

危害性评估的实施流程如下图3所示。

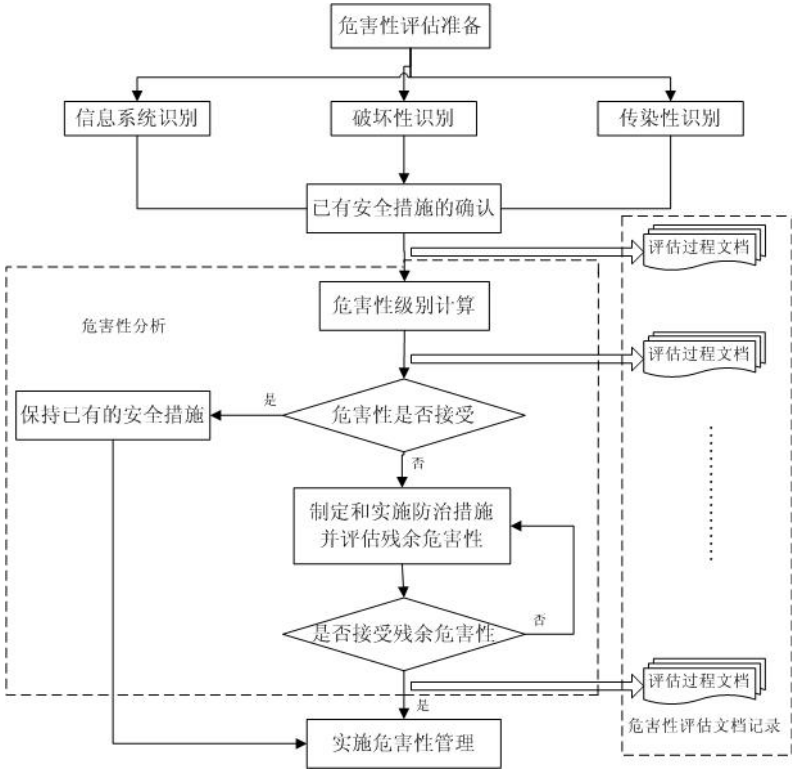


图3 危害性评估实施流程图

9.3 恶意软件危害性评估实施

9.3.1 信息系统识别

9.3.1.1 信息系统分类

危害性评估中信息系统的价值不是以信息系统的经济价值来衡量,而是由信息系统所处行业重要性及所处理业务重要性综合评判的结果。

9.3.1.2 信息系统重要性等级

参照GB /T 22240-2020《信息安全技术 网络安全等级保护定级指南》中4.1安全保护等级定义,将信息系统划分为五个等级,级别越高表示信息系统越重要。表1表明了不同等级的重要性的综合描述。

表1 信息系统等级划分表

等级	标识	描述
5	很高	非常重要,受到恶意软件破坏后会对国家安全造成特别严重危害
4	高	重要,受到恶意软件破坏后会对社会秩序和公共利益造成特别严重危害,或者对国家安全造成严重危害
3	中等	比较重要,受到恶意软件破坏后会对社会秩序和公共利益造成严重危害,或者对国家安全造成危害
2	低	一般重要,受到恶意软件破坏后会对相关公民、法人和其他组织的合法权益造成严重损害或特别严重损害,或者对社会秩序和公共利益造成危害,但不危害国家安全
1	很低	不重要,受到恶意软件破坏后会对相关公民、法人和其他组织的合法权益造成一般损害,但不危害国家安全、社会秩序和公共利益

9.3.2 安全措施识别

9.3.2.1 安全措施识别内容

安全措施的识别以信息系统的部署的恶意软件防护措施为依据,从而对信息系统的安全防护能力进行评估。

9.3.2.2 防护能力赋值

针对同一恶意软件,根据采取不同的安全防护措施,可依据表2对防护能力进行赋值,其中1表示防护能力最高,5表示防护能力最低,如果采用了多种安全措施,以防护能力最高值赋值。

表2 防护能力赋值表

赋值参数	赋值
静态特征检测	5
边界防护	3
动态行为检测	2
基于特征代码检测	4
基于启发式检测	3
云查杀	2

可信计算防护	1
--------	---

防护能力的最终赋值根据表2计算得出，对结果进行等级划分，划分为五级，分别赋予1-5不等的值，由此获得防护能力的级别，如表3所示。

表3 防护能力等级判定表

防护能力赋值	1	2	3	4	5
防护能力等级	1	2	3	4	5

9.3.3 传染性识别

9.3.3.1 传染性识别内容

传染性的识别以信息系统的在确定周期内监测数据为依据，从而对恶意软件进行动态评估。被感染的独立站点数量、感染的计算机台数、地理分布状况、行业分布状况是对恶意软件监测的四个主要属性。

9.3.3.2 传染性赋值

针对同一恶意软件，在一个监测周期内的监测结果是不同的，当其大范围传播、感染的时候，监测数据会有所上升，但随着防治措施的落实，其传播、感染将得到控制，则监测数据必然会有所下降。根据实际操作的可行性，可依据表4对传染性进行赋值，每个监测项目根据实际监测结果，分别赋予1-5不等的值。

表4 恶意软件传染性赋值表

赋值参数	赋值				
	5	4	3	2	1
被感染的独立站点数量（个）：	5	4	2-3	1	0
感染的计算机的数量（台）：	>500	300-500	100-300	10-100	<10
感染的地理分布状况（省市自治区）：	5	3-4	2	1	0
感染的行业分布状况（重点行业）：	5	3-4	2	1	0

传染性的最终赋值根据表4经过各项参数取值相加得出，对结果进行等级划分，划分为五级，分别赋予1-5不等的值，由此获得传染性等级值，如表5所示。

表5 传染性等级判定表

传染性赋值	1-6	7-10	11-14	15-18	19-20
传染性等级	1	2	3	4	5

9.3.4 破坏性识别

9.3.4.1 破坏性识别内容

恶意软件的破坏性识别可以通过传播性、破坏力和复杂性三个属性来描述。

9.3.4.2 破坏性赋值

恶意软件传播性赋值如表6所示。

表6 恶意软件传播性赋值表

赋值参数		赋值
传播途径	通过文件	3
	通过邮件	4
	通过局域网	4
	通过互联网（邮件除外）	5
	通过移动存储设备	4
传播方式	利用系统漏洞传播	4
	利用应用软件漏洞传播	4
	利用系统配置缺陷传播	3
	利用社会工程方法传播	4
	不依赖人的操作	5

恶意软件破坏力赋值如表7所示。

表7 恶意软件破坏力赋值表

赋值参数	赋值
删除/修改文件	4
具有触发事件	3
造成网络阻塞	4
具有持续网络主动传播能力	5
造成系统瘫痪	4
获取敏感信息	4
赋值参数	赋值
系统性能降低	3
网络性能降低	3
改变系统配置	4
造成打印机或其它网络连接设备的故障	3
进程注入	5
对其他进程进行控制	5
具有自我保护功能	5
具有进一步的攻击	4

恶意软件复杂性赋值如表8所示。

表8 恶意软件复杂性赋值表

赋值参数	赋值
是否不具有或者难以获取补丁程序	4
是否利用新的攻击技术	4
是否具有复合型传染方式	4
是否不容易清除	3
当前技术是否具有抵抗恶意软件的能力	5

是否由于数据损坏、信息丢失造成了信誉危机或法律责任	4
---------------------------	---

传播性、破坏力和复杂性的最终赋值可以分别根据表6、表7、表8经过各项参数取值相加得出，对得出的结果进行等级划分，划分为五级，分别赋予1-5不等的值，由此，分别获得传播性、破坏力和复杂性的等级值，如表9、表10、表11所示。

表9 传播性等级判定表

传播性赋值	1-5	6-11	11-25	26-33	34-40
传播性等级	1	2	3	4	5

表10 破坏力等级判定表

破坏力赋值	1-5	6-10	11-28	29-45	46-56
破坏力等级	1	2	3	4	5

表11 复杂性等级判定表

复杂性赋值	1-5	6-10	11-15	16-20	21-24
复杂性等级	1	2	3	4	5

9.4 恶意软件危害性分级

9.4.1 级别分类

恶意软件危害性分级用于评估对信息系统的安全影响，并且把它们对信息系统的威胁划分出明确的等级。这些要素被分别按照相应指标进行级别划分，然后再进行综合评定就可以得到总体的危害性级别，共分为5级，其中五级表示最高级别，依次降低。

9.4.2 危害性级别定义

9.4.2.1 五级（特大）

本级别表示恶意软件可以造成大范围公共网络或者专用网络的拥塞、瘫痪 无法进行数据传输和交换 或者造成信息系统大范围受到攻击或者专用信息系统受到攻击，导致系统瘫痪或者严重的信息泄漏。

9.4.2.2 四级（重大）

本级别表示恶意软件可以通过网络传播。并且能够造成部分网络或者信息系统瘫痪 或者存在潜在的敏感信息泄漏途径；或者删除数据；或者对特定目标发动攻击。

9.4.2.3 三级（严重）

本级别表示恶意软件不能通过网络传播，但是严重影响信息系统正常运行或者造成数据丢失 或者能够通过网络传播，但不具有特别显著的破坏性。

9.4.2.4 二级（一般）

本级别表示恶意软件影响计算机系统正常运行或者改变原有功能。

9.4.2.5 一级（轻微）

本级别表示恶意软件不具有直接对网络和系统的破坏性。

附 录 A

（资料性）

恶意软件危害性计算方法

A.1 破坏性级别的计算

破坏性级别是由传播性、破坏力和复杂性经过综合评判得来的，因此在计算恶意软件危害性级别之前，首先要对破坏性级别进行计算，采用相乘法用公式（1）来计算。

相乘法主要用于两个或多个要素值确定一个要素值的情形，即 $z=f(x, y)=x \otimes y$ ，当 f 为增量函数时，

$\otimes$ 可以为直接相乘，也可以为相乘后取模等。

通过上文表9至表11得到传播性、破坏力和复杂性等级值之后，可以采用相乘法得到破坏性级别值。采用的计算模型方法如下：

当某一属性由三个参数确定时，用公式(1)进行计算，计算的结果四舍五入取整。

$$fun(x, y, z) = \sqrt{\sqrt{x \times y} \times z} \quad (1)$$

由此，可以计算得到破坏性级别值，从而完成对破坏性的识别。

A.2 危害性级别的计算

在完成了信息系统、传染性和破坏性的识别之后，将采用适当的方法与工具确定恶意软件危害性级别的可能性。

在危害性计算中，通常需要对两个要素确定的另一个要素进行计算，因此，提出两种方法进行计算。第一种方法可以采用相乘法；第二种方法可以采用矩阵法，矩阵法的原理如下。

首先需要确定二维计算矩阵，矩阵内各个要素的值根据具体情况和函数递增情况采用数学方法确定，然后将两个元素的值在矩阵中进行比对，行列交叉处即为所确定的计算结果。

矩阵法的原理是：

$$x = \{x_1, x_2, \dots, x_i, \dots, x_m\}, 1 \leq i \leq m, x_i \text{ 为正整数}$$

$$y = \{y_1, y_2, \dots, y_j, \dots, y_n\}, 1 \leq j \leq n, y_j \text{ 为正整数}$$

以要素x和要素y的取值构建一个二维矩阵，如表11所示。矩阵行值为要素y的所有取值，矩阵列值为要素x的所有取值。矩阵内 $m \times n$ 个值即为要素z的取值， $z = \{z_{11}, z_{12}, \dots, z_{ij}, \dots, z_{mn}\}, 1 \leq i \leq m, 1 \leq j \leq n, z_{ij} \text{ 为正整数}$ 。

表A.1 矩阵构造

$x \backslash y$	y1	y2	...	yj	...	yn
x1	z11	z12	...	z1j	...	z1n
x2	z21	z22	...	z2j	...	z2n
...	...	...	...	...	...	...
xi	zi1	zi2	...	zij	...	zin
...	...	...	...	...	...	...
xm	zm1	zm2	...	zmj	...	zmn

z的计算需要根据实际情况确定，矩阵内zij值的计算不一定遵循统一的计算公式，但必须具有统一的增减趋势，即如果f是递增函数，zij值应随着xi与yj的值递增，反之亦然。

矩阵法在危害性分析计算中有广泛的采用，具体方法如下：

a) 计算恶意软件事件发生的可能性

在完成了传染性和安全措施的识别之后，构造恶意软件安全事件发生可能性矩阵，如表A.2所示。

表A.2 恶意软件安全事件发生可能性矩阵

$\begin{matrix} \text{传染性} \\ \text{防护能力} \end{matrix} \backslash$	1	2	3	4	5
1	2	4	7	11	14
2	3	6	10	13	17
3	5	9	12	16	20
4	7	11	14	18	22

5	8	12	17	20	25
---	---	----	----	----	----

然后根据传染性级别值和防护能力级别值在矩阵中进行对照,确定恶意软件安全事件发生可能性值,并通过表A. 3对该值进行等级划分,划分为五级,分别赋予1-5不等的值。

表A. 3 恶意软件安全事件发生可能性等级划分

安全事件发生可能性值	1-5	6-11	12-16	17-21	22-25
发生可能性等级值	1	2	3	4	5

b) 计算恶意软件安全事件造成的损失
在完成了破坏性和信息系统的识别之后,构造恶意软件安全事件造成的损失矩阵,如表A. 4所示。

表A. 4 恶意软件安全事件损失矩阵

破坏性 信息系 统价值	1	2	3	4	5
1	2	4	6	10	13
2	3	5	9	12	16
3	4	7	11	15	20
4	5	8	14	19	22
5	6	10	16	21	25

然后根据破坏性级别值和信息系统级别值在矩阵中进行对照,确定恶意软件安全事件造成的损失值并通过表A. 5对该值进行等级划分,划分为五级,分别赋予1-5不等的值。

表A. 5 恶意软件安全事件损失等级划分

恶意软件安全事件损失值	1-5	6-10	11-15	16-21	22-25
安全事件损失等级值	1	2	3	4	5

c) 计算恶意软件危害性级别
在分别得到恶意软件安全事件发生可能性等级和恶意软件安全事件损失等级之后,构造恶意软件危害性矩阵,如表A. 6所示。

表A. 6 恶意软件危害性级别矩阵

可能性 造成损失	1	2	3	4	5
1	3	6	9	12	16
2	5	8	11	15	18
3	6	9	13	17	21
4	7	11	16	20	23
5	9	14	20	23	25

然后根据恶意软件安全事件发生可能性等级值和恶意软件安全事件损失等级值在矩阵中进行对照,确定恶意软件危害性值。最终根据该值,通过表A. 7判定恶意软件危害性级别。

表A. 7 恶意软件危害性等级划分

恶意软件危害性值	1-6	7-12	13-18	19-23	24-25
恶意软件危害性等级	一级	二级	三级	四级	五级

根据上述介绍的计算方法，可以最终确定恶意软件危害性级别。